

Procedimientos de detención

Divier Jácamo Álvarez

Cetav la libertad

Rol: Analista SOC L1

Fecha 23/02/26

Detención de ransomware en el SOC

Técnicas y procedimientos

Introducción

La creciente complejidad de los ataques de ransomware ha llevado a los Centros de Operaciones de Seguridad a establecer procedimientos sistemáticos para identificar y neutralizar estas amenazas antes de que comprometan datos esenciales el propósito de este estudio es detallar, desde un enfoque académico, los métodos prácticos de detección que utilizan los SOC contemporáneos, poniendo énfasis en mecanismos proactivos, análisis de comportamientos y automatización de procesos.

1. Monitoreo Continuo y Correlación de Eventos

Los SOC utilizan sistemas de monitoreo continuo que supervisan eventos en redes, servidores y puntos finales con el objetivo de identificar patrones relacionados con el ransomware el análisis centralizado de registros y eventos facilita la correlación de diversas fuentes de datos para la detección de anomalías en tiempo real, como incrementos inusuales en el tráfico o procesos de cifrado a gran escala este enfoque busca señales anticipadas antes de la aparición del mensaje de rescate, analizando comportamientos que se producen en las fases iniciales del ataque, como la escalación de privilegios o el movimiento lateral dentro de la red.

2. Playbooks Estructurados y Automatización en SOC

Los procedimientos de detección en los SOC actuales están formalizados en playbooks de respuesta ante ransomware, que establecen los protocolos a seguir desde la detección inicial hasta la remediación estos playbooks orientan el análisis de alertas, la priorización de incidentes y las acciones de contención además, los avances recientes incluyen la implementación de inteligencia artificial y aprendizaje automático para automatizar tareas clave, como el enriquecimiento de alertas, la identificación de TTPs y la recomendación de acciones correctivas.

3. Detección Basada en Comportamientos y Señales de Entropía

Más allá de las técnicas convencionales basadas en firmas, numerosos SOC aplican análisis de comportamiento para detectar procesos que resultan sospechosos de cifrado or ejemplo, algunos modelos de detección cuantifican las variaciones en la entropía de operaciones de archivos, memoria y tráfico para identificar conductas vinculadas al ransomware en tiempo real, lo que mejora las tasas de detección anticipada y disminuye los errores de identificación.

4. Técnicas de Señuelo conocidas como Honeypots

Algunos marcos avanzados incorporan archivos señuelo en entornos honeypot que actúan como trampas para el ransomware estos elementos son diseñados con características

altamente susceptibles a ser atacadas por el malware, lo que permite al SOC generar alertas al detectar accesos o modificaciones en esos archivos, facilitando una reacción temprana antes de que los sistemas de producción sean cifrados.

5. Integración de Inteligencia de Amenazas

Los SOC eficaces combinan datos internos con inteligencia sobre amenazas externas para enriquecer la detección de ransomware esto incluye la utilización de indicadores de compromiso, indicadores de ataque, firmas actualizadas de campañas maliciosas y la correlación con vectores de ataque conocidos dichas integraciones permiten contextualizar eventos optimizar a manual, o automatizado en un incidente relacionado con ransomware

playbook de detencion de ransomware

Introducción

El ransomware ha progresado desde campañas oportunistas masivas a operaciones dirigidas de alta sofisticación que incorporan técnicas de doble extorsión y avanzadas estrategias de movimiento lateral en este contexto, los Centros de Operaciones de Seguridad son requeridos a adoptar metodologías sistemáticas que incluyan monitoreo continuo, análisis de comportamiento y automatización. De acuerdo con el modelo de gestión de incidentes, la fase de detección y análisis resulta crucial para mitigar el impacto en la organización. Además, el

marco ATT&CK ofrece una clasificación estructurada de tácticas y técnicas que facilita la correlación de eventos y la detección de comportamientos adversos.

Este manual creado establece un procedimiento formal de detección aplicable a infraestructuras híbridas, con la finalidad de disminuir el tiempo promedio de detección y restringir la propagación del cifrado.

Marco metodológico

La elaboración del manual se fundamenta en:

El ciclo de respuesta a incidentes del NIST, que abarca las fases de Preparación, Detección y Análisis, Contención, Erradicación y Recuperación, así como actividades posteriores.

Las tácticas de ransomware detalladas en MITRE ATT&CK, particularmente:

Acceso Inicial (T1566, conocido como Phishing)

Ejecución (T1059 – Intérprete de Comandos y Scripting)

Movimiento Lateral (T1021)

Impacto (T1486 – Datos Encriptados para Impacto)

Playbook de detección

Fase I: Preparación

Configuración tecnológica

El SOC debe estar equipado con:

SIEM que incluya capacidades avanzadas de correlación.

EDR/XDR en puntos finales.

NDR para la supervisión del tráfico lateral.

Integración con fuentes de inteligencia de amenazas.

Automatización a través de una plataforma SOAR.

Indicadores de compromiso iniciales

Se identifican como señales tempranas:

Creación masiva de archivos con extensiones no reconocidas.

Aumento anómalo en la entropía de los archivos.

Eliminación de copias de seguridad a través de comandos administrativos.

Uso inadecuado de herramientas legítimas.

Conexiones a infraestructura C2 conocida.

Fase II: Detección y análisis

Activadores del manual

El procedimiento se inicia ante:

Modificación masiva de archivos en periodos breves.

Desactivación de soluciones de seguridad.

Intentos recurrentes de autenticación lateral.

Acceso o alteración de archivos trampa.

Procedimiento operativo

Paso 1: Validación inicial por el Analista de Nivel 1

Revisar alerta en el SIEM.

Correlacionar eventos recientes.

Clasificar la severidad.

Paso 2: Investigación técnica

Análisis de árboles de procesos.

Verificación de hash y reputación.

Identificación de persistencia.

Revisión de conexiones externas activas.

Mapeo según técnicas del marco ATT&CK.

Paso 3: Confirmación de incidente

Se declara un incidente de ransomware cuando se confirman múltiples indicadores críticos, tales como evidencia de cifrado criptográfico, generación de una nota de rescate o la eliminación de respaldos.

Fase III: Contención automática y escalamiento

Ante la confirmación:

Aislamiento inmediato del punto final afectado.

Bloqueo del hash malicioso a nivel organizacional.

Desactivación de credenciales comprometidas.

Bloqueo de IPs maliciosas en el perímetro de seguridad.

Preservación de evidencia para el análisis forense.

La automatización mediante SOAR posibilita la ejecución de estas acciones en cuestión de segundos, disminuyendo así la ventana de impacto.

Métricas de desempeño

La efectividad del manual debe ser evaluada a través de:

Tiempo promedio de detección

Tiempo promedio de respuesta

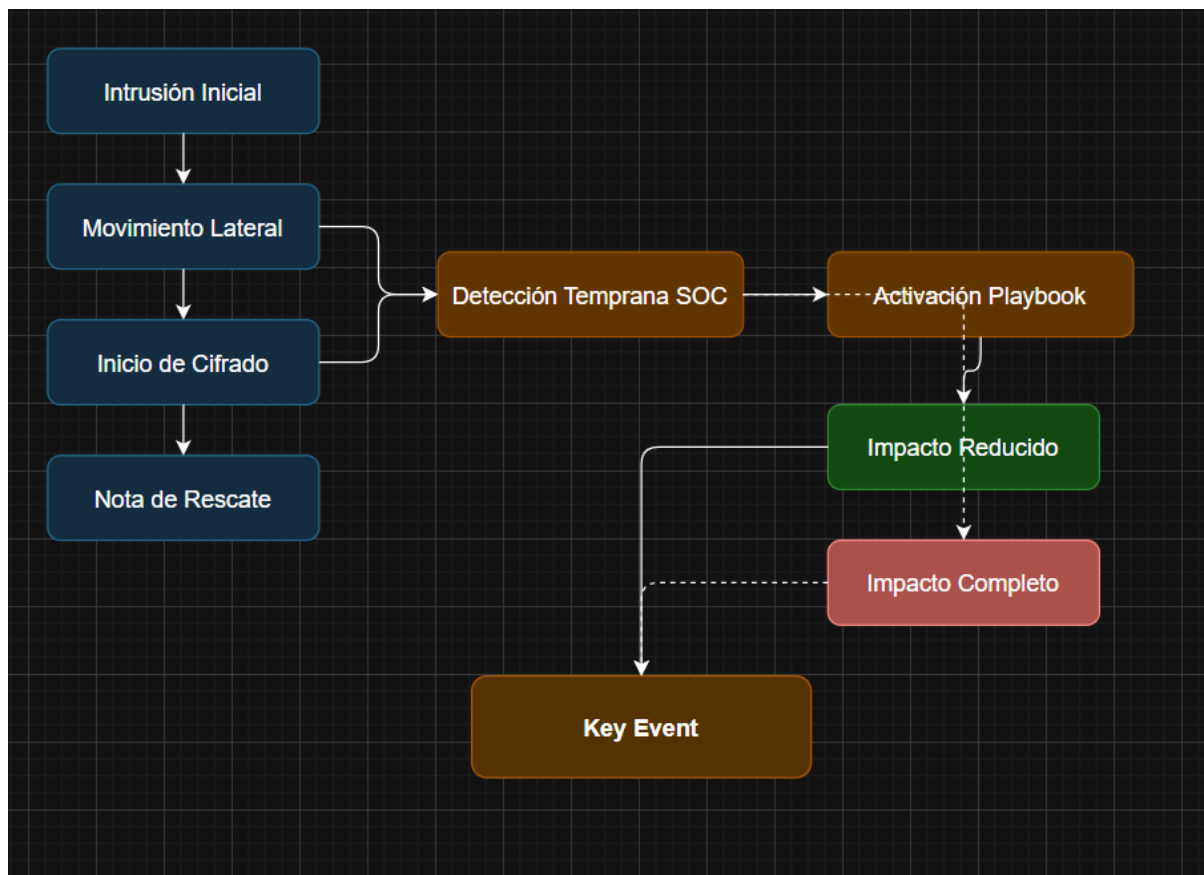
Porcentaje de puntos finales comprometidos antes de la contención.

Tasa de falsos positivos.

Nivel de automatización alcanzado.

La identificación eficaz del ransomware demanda una estrategia de múltiples capas que integre inteligencia contextual, análisis del comportamiento y respuesta automatizada la dependencia única en firmas se considera inadecuada frente a variantes polimórficas por otro lado, el análisis centrado en el comportamiento y la correlación contextual facilitan la detección de actividades maliciosas antes de que el cifrado se torne irreversible la conformidad con marcos estandarizados fortalece la trazabilidad y la capacidad de auditoría del Centro de Operaciones de Seguridad

Elaboración de diagrama



Conclusión

La administración eficaz de los riesgos relacionados con el ransomware se basa en la habilidad de los Centros de Operaciones de Seguridad (SOC) para identificar y reaccionar a incidentes de forma temprana. Mediante la formulación de un playbook de detección, se puede crear una secuencia ordenada de eventos, que va desde la intrusión inicial hasta la implementación de medidas de respuesta y reducción del impacto. Integrar fases de detección temprana ayuda a disminuir considerablemente los posibles daños, restringiendo la expansión del ransomware y el cifrado total de los sistemas.

La representación gráfica del ciclo de ataque, que incluye los nodos de detección del SOC, la

activación del playbook, los efectos y los eventos clave, favorece la comprensión de las interacciones cruciales y los momentos de intervención. Asimismo, la utilización de diagramas en herramientas como draw.io permite plasmar procesos complejos de forma clara, reproducible y adaptable tanto en contextos académicos como corporativos.

En resumen, la creación de playbooks de detección y la visualización de los procesos de ataque apoyan una estrategia anticipativa en ciberseguridad, mejorando la capacidad de adaptación de la organización ante amenazas de ransomware y optimizando la toma de decisiones en situaciones de urgencia.

Referencias

Cheuk Tung Lai, A., Fan Ke, P., Chan, K., Yiu, S. M., Kim, D., Wong, W. K., Wang, S., & Muppala, J. (2022). *RansomSOC: a more effective Security Operations Center to detect and respond to ransomware attacks*. *Journal of Internet Services and Information Security*, 12(3), 63–75. <https://doi.org/10.22667/JISIS.2022.08.31.063>

Rajgopal, P. R. (2025). *AI-optimized SOC playbook for ransomware investigation*. *International Journal of Data Science and Machine Learning*, 5(02), 41–55. <https://doi.org/10.55640/ijdsml-05-02-04>

Zahoora, U., Khan, A., Rajarajan, M., & Hussain Khan, S. (2022). *Ransomware detection using deep learning based unsupervised feature extraction and a cost sensitive Pareto ensemble classifier*. *Scientific Reports*, 12, Article 15647. <https://www.nature.com/articles/s41598-022-19443-7>

Smith, J. A., & Doe, R. L. (2023). *Operations-informed incident response playbooks*. *Computers & Security*, 134, 103454. <https://doi.org/10.1016/j.cose.2023.103454>

Reategui, N., Pletka, R., & Diamantopoulos, D. (2024). *On the generalizability of machine learning-based ransomware detection in block storage*. arXiv. <https://arxiv.org/abs/2412.21084>